CABINET VALDIÈRE AUDIT & CONSEIL

RAPPORT D’AUDIT

Audit de l’infrastructure informatique

Orvalis · groupe logistique

Mission réalisée du 4 mai au 12 juin 2026 · version finale du 26 juin 2026

Document confidentiel · diffusion restreinte au comité de direction et au service informatique d’Orvalis
Entreprise, cabinet et données fictifs, créés pour une formation.

Sommaire

Partie	Page
1. Synthèse pour la direction	3
2. Périmètre et méthode	4
3. Présentation du système d’information	6
4. Serveurs et obsolescence	8
5. Réseau et Wi-Fi	11
6. Postes de travail et correctifs	14
7. Identités et accès	16
8. Sauvegardes et reprise	21
9. Stockage, messagerie, applications	24
10. Supervision et exploitation	27
11. Inventaire et processus	31
12. Conformité et usages de l’IA	35
13. Synthèse des constats et plan d’action	37
Annexes	39

1. Synthèse pour la direction

Orvalis a confié au Cabinet Valdière Audit & Conseil l’audit de son infrastructure informatique entre le 4 mai et le 12 juin 2026. L’objectif était double : mesurer la robustesse du socle technique qui soutient l’activité des neuf entrepôts, et identifier les risques à traiter en priorité avant la saison haute de fin d’année.

Le service informatique d’Orvalis, composé de quatorze personnes, assure un niveau de service apprécié des métiers. Les entretiens menés sur cinq sites font ressortir une équipe réactive et une bonne connaissance du terrain. Le socle a toutefois grandi plus vite que les processus qui l’encadrent.

L’audit relève des fragilités dans quatre domaines : les accès à privilèges, la capacité à restaurer les données, l’obsolescence de certains serveurs et la surveillance en dehors des heures ouvrées. À ces quatre domaines s’ajoute une connaissance incomplète du parc de postes de travail.

Aucune de ces fragilités n’a encore causé d’incident majeur. Leur combinaison expose cependant Orvalis à un arrêt prolongé des entrepôts en cas d’attaque ou de panne survenant un week-end. Le plan d’action proposé en partie 13 peut être conduit en six mois, sans recrutement, en priorisant les mesures à faible coût.

2. Périmètre et méthode

Le périmètre couvre l’ensemble de l’infrastructure gérée par le service informatique : serveurs, stockage, sauvegardes, réseau étendu et local, Wi-Fi des entrepôts, postes de travail, annuaire, messagerie, supervision, ainsi que les processus d’exploitation associés. Les applications métier ne sont examinées que sous l’angle de leur hébergement.

La méthode combine trois sources : des entretiens individuels, l’analyse documentaire et des contrôles techniques par échantillonnage. Les contrôles ont été réalisés en lecture seule, avec un compte d’audit dédié créé pour la mission et supprimé à son issue.

Chaque constat est coté selon un niveau de risque à quatre niveaux, qui combine la probabilité d’occurrence et la gravité de l’impact sur l’activité : faible, modéré, élevé, critique. La cotation a été partagée avec le responsable informatique avant la rédaction finale.

Niveau	Signification
Faible	Amélioration souhaitable
Modéré	À traiter dans l’année
Élevé	À traiter dans les six mois
Critique	À traiter dans les trois mois

2. Calendrier et entretiens

La mission s’est déroulée en trois phases : cadrage et collecte documentaire (deux semaines), entretiens et contrôles sur site (trois semaines), analyse et restitution (une semaine). Vingt-deux entretiens ont été menés, au siège et dans les entrepôts de Lyon, Rennes, Lille et Bordeaux.

Semaine	Activité	Livrable
19	Réunion de lancement, demande de documents	Note de cadrage
20	Analyse documentaire	Liste de questions
21	Entretiens au siège	Comptes rendus
22	Visites de Lyon et Rennes	Comptes rendus
23	Visites de Lille et Bordeaux, contrôles techniques	Relevés de contrôle
24	Analyse, cotation, restitution	Présent rapport

La liste détaillée des personnes rencontrées et des documents consultés figure en annexe B.

3. Présentation du système d’information

Orvalis emploie 1 400 salariés répartis entre un siège parisien et neuf entrepôts. L’activité repose sur un logiciel de gestion d’entrepôt (WMS) centralisé au siège, un logiciel de transport, la messagerie Microsoft 365 et des partages de fichiers utilisés au quotidien par les quais pour les bons de préparation.

Le système d’information compte environ 1 090 postes de travail, 14 serveurs physiques et virtuels, 98 bornes Wi-Fi, 640 scanners de quai et 212 files d’impression. Le service informatique traite en moyenne 1 700 tickets par mois.

L’architecture est centralisée : la quasi-totalité des services sont hébergés au siège et accessibles depuis les entrepôts par des liens fibre. Cette centralisation simplifie l’exploitation, mais rend l’activité des entrepôts dépendante de la disponibilité du siège.

3. Cartographie des sites

Site	Salariés	Bornes Wi-Fi	Lien réseau	Imprimantes
Siège (Paris)	210	0	Fibre 1 Gb/s + secours 4G	62
Lyon	220	14	Fibre 500 Mb/s	38
Rennes	150	11	Fibre 500 Mb/s	29
Lille	140	12	Fibre 300 Mb/s	27
Marseille	130	10	Fibre 300 Mb/s	24
Bordeaux	120	9	Fibre 300 Mb/s	22
Nantes	115	9	Fibre 300 Mb/s	21
Strasbourg	105	8	Fibre 200 Mb/s	19
Toulouse	110	9	Fibre 300 Mb/s	20
Orléans	100	8	Fibre 200 Mb/s	18

Les entrepôts de Lyon, Rennes et Lille concentrent à eux seuls 36 % des salariés des entrepôts et la plus forte activité de préparation.

4. Inventaire des serveurs

Serveur	Rôle	Système	Site	Support éditeur
DC-01	Contrôleur de domaine	Windows Server 2019	Siège	Supporté
DC-02	Contrôleur de domaine	Windows Server 2019	Lyon	Supporté
FS-01	Fichiers siège	Windows Server 2019	Siège	Supporté
FS-02	Fichiers entrepôts nord-ouest	Windows Server 2019	Siège	Supporté
FS-03	Fichiers entrepôts sud-est	Windows Server 2019	Siège	Supporté
FS-04	Archives	Windows Server 2016	Siège	Support étendu
PRT-01	Impression	Windows Server 2016	Siège	Support étendu
APP-04	Serveur applicatif WMS	Windows Server 2022	Siège	Supporté
SQL-02	Base de données WMS	Windows Server 2022	Siège	Supporté
TRS-01	Logiciel de transport	Windows Server 2012 R2	Siège	Hors support
BKP-01	Serveur de sauvegarde	Windows Server 2019	Lyon	Supporté
SUP-01	Supervision	Linux (distribution 2019)	Siège	Hors support
LIC-01	Serveur de licences	Windows Server 2012 R2	Siège	Hors support
RDS-01	Bureau à distance	Windows Server 2022	Siège	Supporté

4. Obsolescence

CONSTAT 3

RISQUE ÉLEVÉ

Trois serveurs hors support éditeur

Trois serveurs fonctionnent avec un système d’exploitation qui ne reçoit plus de correctifs de sécurité : TRS-01 (logiciel de transport) et LIC-01 (serveur de licences) sous Windows Server 2012 R2, et SUP-01 (supervision) sous une distribution Linux de 2019 sans mise à jour.

TRS-01 est particulièrement exposé : il échange quotidiennement des fichiers avec les transporteurs et reste joignable depuis l’extérieur pour l’un d’eux. Une vulnérabilité non corrigée sur ce serveur offrirait un point d’entrée dans le réseau du siège.

Deux autres serveurs, FS-04 et PRT-01, sont en support étendu jusqu’en janvier 2027. Leur remplacement doit être planifié dès maintenant.

> **Recommandation** · Migrer TRS-01 en priorité, isoler LIC-01 et SUP-01 dans un segment réseau dédié en attendant leur remplacement, planifier la migration de PRT-01 et FS-04 avant la fin de l’année.

4. Plan de renouvellement proposé

Serveur	Action	Échéance proposée	Charge estimée
TRS-01	Migration vers Windows Server 2022	T3 2026	8 jours
LIC-01	Isolement puis remplacement	T3 2026	3 jours
SUP-01	Nouvelle plateforme de supervision	T4 2026	15 jours
PRT-01	Migration vers un nouveau serveur	T4 2026	6 jours
FS-04	Migration des archives	T4 2026	4 jours

Les charges sont exprimées en jours de travail de l’équipe infrastructure, hors délais d’achat.

5. Réseau étendu et liens inter-sites

Chaque entrepôt est relié au siège par un lien fibre dédié. Le siège dispose d’un lien de secours 4G ; les entrepôts n’en disposent pas. En cas de coupure du lien principal, un entrepôt perd l’accès au WMS et aux partages de fichiers.

Les mesures réalisées montrent des liens correctement dimensionnés en charge normale, avec des pointes à 70 % d’utilisation à Lyon entre 6 h et 8 h, au moment des préparations du matin.

Le plan d’adressage est documenté et cohérent. Les règles de filtrage entre sites sont en revanche très ouvertes : tous les postes des entrepôts peuvent joindre tous les serveurs du siège, y compris ceux qui n’ont aucun usage pour eux.

5. Wi-Fi des entrepôts

Le Wi-Fi est indispensable à l’activité : les 640 scanners de quai l’utilisent en permanence. Il est maintenu par deux prestataires selon les sites. Les entretiens font état d’une qualité inégale, avec des coupures fréquentes signalées à Lyon, Rennes et Lille.

Site	Bornes	Âge moyen	Coupures signalées (T1)
Lyon	14	6 ans	41
Rennes	11	6 ans	33
Lille	12	6 ans	29
Marseille	10	2 ans	8
Bordeaux	9	2 ans	6
Nantes	9	3 ans	9
Strasbourg	8	2 ans	5
Toulouse	9	2 ans	7
Orléans	8	3 ans	6

Les trois sites les plus touchés ont les bornes les plus anciennes et dépendent du même prestataire.

5. Sécurité périmétrique

Le siège est protégé par un pare-feu en haute disponibilité, correctement maintenu. Les règles d’accès depuis Internet sont limitées et documentées, à une exception près : un accès historique d’un transporteur vers TRS-01, ouvert en 2019 et jamais revu.

Les accès distants des salariés passent par un VPN avec authentification à deux facteurs. Les prestataires disposent en revanche de comptes VPN nominatifs sans second facteur, dont quatre n’ont pas été utilisés depuis plus de six mois.

- Revoir l’accès entrant vers TRS-01 et le limiter aux adresses du transporteur.
- Imposer le second facteur aux comptes VPN des prestataires.
- Désactiver les comptes VPN inutilisés depuis plus de 90 jours.

6. Parc de postes de travail

Le parc compte environ 1 090 postes selon l’outil de gestion, dont 640 postes fixes et 450 portables. Le chiffre exact n’a pas pu être établi (voir constat 5, page 31).

86 % des postes contrôlés fonctionnent sous Windows 11. Les postes encore sous Windows 10 sont principalement des postes de quai utilisés pour l’impression des étiquettes, maintenus pour des raisons de compatibilité de pilotes.

Système	Part du parc contrôlé
Windows 11	86 %
Windows 10	13 %
Autre	1 %

6. Gestion des correctifs

Les correctifs de sécurité des postes sont déployés automatiquement chaque mois, avec un taux de conformité de 94 % à trente jours. C’est un bon résultat.

Sur les serveurs, les correctifs sont appliqués manuellement, sans calendrier formalisé. Les contrôles montrent un retard moyen de 47 jours, et de plus de 120 jours sur trois serveurs.

La mise à jour automatique des pilotes de périphériques est activée sur les serveurs, y compris sur le serveur d’impression. Cette pratique peut provoquer des incompatibilités avec les imprimantes d’étiquettes.

- Formaliser un calendrier mensuel de correctifs serveurs, avec une fenêtre de maintenance.
- Désactiver la mise à jour automatique des pilotes sur PRT-01.

7. Annuaire et gestion des identités

L’annuaire compte 1 512 comptes utilisateurs actifs pour 1 400 salariés. L’écart s’explique par des comptes de prestataires, des comptes génériques de quai et des comptes de personnes ayant quitté l’entreprise.

Le processus de départ repose sur un courriel des ressources humaines au support. Il fonctionne pour les départs planifiés mais pas pour les fins de mission des intérimaires : 64 comptes d’intérimaires sont restés actifs après la fin de leur contrat.

Type de compte	Nombre
Salariés	1 384
Prestataires	38
Génériques de quai	26
Anciens intérimaires encore actifs	64

7. Comptes à privilèges

CONSTAT 1

RISQUE CRITIQUE

Douze comptes administrateurs sans double authentification

L’annuaire compte 31 comptes disposant de droits d’administration sur le domaine ou sur les serveurs. Douze d’entre eux ne sont protégés par aucun second facteur d’authentification : un mot de passe suffit pour les utiliser.

Parmi ces douze comptes figurent deux comptes d’administrateur du domaine, utilisés au quotidien par l’équipe infrastructure pour des tâches courantes, et trois comptes de prestataires dont les mots de passe n’ont pas été changés depuis plus d’un an.

La compromission d’un seul de ces comptes donnerait à un attaquant le contrôle complet du système d’information, y compris des sauvegardes.

> **Recommandation** · Activer le second facteur sur les 31 comptes à privilèges sous trois mois, créer des comptes d’administration distincts des comptes de travail quotidiens, changer les mots de passe des comptes de prestataires.

7. Authentification des utilisateurs

Le second facteur d’authentification a été déployé pour les utilisateurs de Microsoft 365 en 2025. Le déploiement est presque achevé : 12 % des comptes utilisateurs n’ont pas encore enrôlé de second facteur, essentiellement des comptes de quai partagés et des salariés sans téléphone professionnel.

Ce chiffre ne concerne pas les comptes à privilèges, traités au constat 1 (page 17). Il ne présente pas le même niveau de risque, les comptes concernés n’ayant pas de droits d’administration.

La politique de mot de passe impose 14 caractères et une expiration à 180 jours. Le libre-service de réinitialisation est disponible mais encore peu connu dans les entrepôts.

- Équiper les salariés de quai d’une méthode adaptée (clé physique ou application sur appareil partagé).
- Communiquer sur la réinitialisation en libre-service.

7. Comptes de service

Vingt comptes de service font fonctionner les applications et les tâches planifiées. Leurs mots de passe ne sont jamais changés et sont connus de plusieurs membres de l’équipe. Le mot de passe du compte de service de sauvegarde (svc-backup) figure dans un fichier texte sur un partage de l’équipe.

Plusieurs comptes de service disposent de droits très supérieurs à leur besoin, dont deux comptes membres du groupe des administrateurs du domaine.

- Stocker les mots de passe des comptes de service dans un coffre-fort numérique.
- Réduire les droits des comptes de service au strict nécessaire.
- Supprimer le fichier texte contenant le mot de passe de svc-backup.

7. Revue des habilitations

Les droits d’accès aux partages de fichiers sont accordés sur demande des responsables, mais jamais revus. Lors d’un changement de service ou de site, les nouveaux droits sont ajoutés sans retirer les anciens.

Sur un échantillon de 50 salariés ayant changé de poste depuis 2024, 31 conservent des accès à des dossiers de leur ancien service. Ce cumul de droits prend une importance nouvelle avec le déploiement des assistants d’IA, qui peuvent rechercher dans tous les documents accessibles à un utilisateur.

- Mettre en place une revue annuelle des droits par les responsables de service.
- Retirer les anciens droits lors de chaque mutation.

8. Architecture de sauvegarde

Les serveurs sont sauvegardés chaque nuit par un agent installé sur chacun d’eux, vers le serveur BKP-01 situé à Lyon. Une copie hebdomadaire est envoyée vers un stockage externe. La politique de conservation est de 30 jours pour les sauvegardes quotidiennes et de 12 mois pour les hebdomadaires.

Le taux de réussite des sauvegardes est suivi chaque matin par l’exploitation et dépasse 98 % sur les trois derniers mois. Les échecs sont relancés manuellement.

La copie externe n’est pas isolée : elle reste accessible avec les mêmes identifiants que la sauvegarde principale, ce qui l’expose en cas de compromission des comptes à privilèges (voir constat 1).

8. Restauration

CONSTAT 2

RISQUE ÉLEVÉ

Sauvegardes non testées depuis neuf mois

Une sauvegarde réussie ne garantit pas une restauration réussie. Le dernier test de restauration documenté date de septembre 2025, soit neuf mois avant l’audit. Il portait sur un seul fichier.

Aucune restauration complète d’un serveur n’a jamais été réalisée. Les durées de restauration annoncées par l’équipe (« quelques heures ») ne s’appuient sur aucune mesure. Le volume des partages de fichiers des entrepôts laisse penser qu’une restauration complète prendrait plus d’une journée.

En cas de rançongiciel, Orvalis découvrirait la capacité réelle de restauration au moment où elle est indispensable.

> **Recommandation** · Réaliser un test de restauration mensuel, alterné entre fichiers et serveur complet, et en mesurer la durée ; isoler la copie externe avec des identifiants distincts.

8. Plan de reprise d’activité

Orvalis ne dispose pas de plan de reprise d’activité formalisé. Les entretiens montrent que chaque membre de l’équipe sait ce qu’il ferait, mais que personne ne connaît l’ordre de redémarrage des services ni les durées d’interruption acceptables pour les métiers.

Les directeurs d’entrepôt interrogés estiment qu’un arrêt du WMS de plus de quatre heures en période haute entraînerait des pénalités contractuelles avec les clients.

- Définir avec les métiers la durée d’interruption acceptable pour chaque service.
- Rédiger un plan de reprise et le tester une fois par an.

9. Stockage des fichiers

Serveur	Volume	Capacité	Occupation (juin 2026)	Croissance mensuelle
FS-01	D:	2 To	61 %	1,2 %
FS-02	D:	1 To	74 %	2,8 %
FS-03	D:	1 To	79 %	2,1 %
FS-04	D:	4 To	55 %	0,4 %

Les volumes des entrepôts (FS-02 et FS-03) croissent rapidement. Les alertes d’espace disque sont configurées à 90 % d’occupation. À ce rythme, FS-02 et FS-03 atteindront ce seuil avant la fin de l’année. Une part de la croissance de FS-02 provient des journaux techniques, dont la purge n’est pas surveillée.

9. Messagerie et collaboration

La messagerie et les outils collaboratifs sont fournis par Microsoft 365. Les paramètres de sécurité sont globalement conformes aux recommandations de l’éditeur. La journalisation des accès est activée et conservée 180 jours.

Les sites SharePoint créés par les équipes se sont multipliés : 146 sites, dont 38 sans activité depuis un an. Neuf sites sont partagés avec « tous les utilisateurs de l’entreprise », dont un contenant des fichiers de paie.

- Corriger en priorité le partage du site contenant des fichiers de paie.
- Archiver les sites inactifs.
- Revoir les partages avant tout déploiement d’un assistant d’IA ayant accès aux documents.

9. Applications métier

Le WMS est hébergé sur APP-04 et SQL-02, deux serveurs récents et correctement maintenus. L’éditeur intervient à distance pour les mises à jour, avec un compte dédié dont l’usage est journalisé.

Le logiciel de transport, hébergé sur TRS-01, est le point faible applicatif : il fonctionne sur un système hors support (constat 3) et son éditeur ne garantit pas la compatibilité avec une version récente de Windows Server. Un échange est en cours avec l’éditeur.

10. Outillage de supervision

La supervision repose sur la plateforme SUP-01, qui surveille la disponibilité des serveurs, l’espace disque, les bornes Wi-Fi et la réussite des sauvegardes. Elle compte 1 260 points de contrôle.

Les alertes sont envoyées par courriel. Il n’existe ni tableau de bord partagé ni regroupement des alertes : une coupure de lien peut générer plusieurs dizaines d’alertes simultanées, ce qui contribue à une forme de lassitude de l’équipe.

Type d’alerte	Volume mensuel moyen	Destinataire
Bornes Wi-Fi	210	reseau@
Espace disque	24	supervision@
Sauvegardes	31	supervision@
Disponibilité serveurs	12	supervision@

10. Alertes hors heures ouvrées

CONSTAT 4

RISQUE ÉLEVÉ

Alertes de supervision non relues le week-end

Les alertes de supervision sont envoyées à des boîtes partagées (supervision@ et reseau@) consultées par l’exploitation pendant les heures ouvrées. Le week-end et la nuit, personne ne les lit.

L’astreinte existe, mais elle n’est déclenchée que par un appel téléphonique des entrepôts. Elle ne reçoit aucune alerte automatique. Sur les trois derniers mois, 41 alertes critiques émises le week-end n’ont été lues que le lundi matin.

Les entrepôts travaillent le samedi et préparent les expéditions du lundi dès 6 h. Un incident né un samedi peut donc rester invisible jusqu’à l’arrivée des équipes, alors que la supervision l’avait signalé.

> **Recommandation** · Envoyer les alertes critiques à l’astreinte (SMS ou application mobile), y compris la nuit et le week-end ; revoir les destinataires et les seuils à chaque changement d’infrastructure.

10. Astreinte et escalade

L’astreinte est assurée à tour de rôle par cinq membres de l’équipe, du vendredi 18 h au lundi 7 h. La procédure d’escalade est connue mais non écrite. Les numéros d’appel figurent dans un fichier tenu à jour par le responsable d’exploitation.

Aucun bilan des astreintes n’est réalisé : on ne sait pas combien d’appels sont reçus ni combien de temps prend leur traitement.

- Écrire la procédure d’escalade.
- Tenir un registre des interventions d’astreinte et en faire le bilan chaque trimestre.

10. Gestion des incidents

Les incidents sont enregistrés dans l’outil de ticketing, avec une catégorie, une priorité et un site. Les délais de résolution attendus sont définis par priorité (4, 8, 24 et 72 heures).

Le suivi des indicateurs est réalisé chaque mois à la main dans un tableur, à partir d’un export. Ce travail prend environ une journée par mois à la delivery manager.

Les incidents majeurs ne font pas l’objet d’une analyse après coup. Les causes profondes restent donc rarement identifiées, et certains incidents se répètent.

- Automatiser la production du reporting mensuel.
- Réaliser une analyse sans blâme après chaque incident majeur.

11. Inventaire du parc

CONSTAT 5

RISQUE MODÉRÉ

Inventaire des postes incomplet

L’outil de gestion du parc recense 1 090 postes. L’annuaire en compte 1 163, et l’outil de déploiement des correctifs 1 041. Aucune de ces trois sources n’est à jour, et aucun rapprochement n’est réalisé.

Lors des visites de site, 23 postes de quai n’apparaissaient dans aucun outil. Ces postes ne reçoivent pas de correctifs et ne sont pas protégés par l’antivirus géré.

Sans inventaire fiable, Orvalis ne peut ni garantir que tous ses postes sont protégés, ni planifier correctement leur renouvellement.

> **Recommandation** · Rapprocher chaque mois les trois sources d’inventaire, traiter les écarts, et rattacher chaque poste à un site et à un responsable.

11. Gestion des changements

Les changements importants passent par un comité hebdomadaire, qui valide la description, les impacts et le plan de retour arrière. Le processus est respecté pour les changements planifiés.

La fiche de changement ne prévoit aucune vérification des effets sur la supervision et sur les tâches automatiques (purges, sauvegardes, tâches planifiées). Une mise à jour peut donc modifier un paramètre sans que personne ne vérifie ensuite que la surveillance correspondante fonctionne toujours.

- Ajouter à la fiche de changement une rubrique « supervision et tâches automatiques ».
- Prévoir une vérification à J+1 de chaque changement important.

11. Fournisseurs et contrats

Prestataire (fictif)	Périmètre	Sites	Échéance
NetQuai Services	Wi-Fi et réseau local	Lyon, Rennes, Lille	31/12/2026
Aerolink Réseaux	Wi-Fi et réseau local	Six autres entrepôts	30/06/2028
PrintLog Solutions	Impression	Tous	28/02/2027
Éditeur WMS	Maintenance applicative	Siège	31/12/2027

Les contrats ne prévoient pas tous de pénalités en cas de dépassement des délais d’intervention. Le contrat NetQuai, qui couvre les trois sites les plus touchés par les coupures Wi-Fi, n’en prévoit aucune.

11. Documentation et base de connaissances

Les procédures d’exploitation existent pour les tâches principales, mais 60 % d’entre elles ont plus de trois ans. Plusieurs décrivent des serveurs qui n’existent plus.

La base de connaissances destinée aux utilisateurs compte 34 articles, dont la plupart rédigés en 2022. Les techniciens disent résoudre « les mêmes problèmes chaque semaine » sans que les solutions soient capitalisées.

- Mettre à jour les procédures d’exploitation critiques en priorité.
- Transformer chaque incident récurrent résolu en article de base de connaissances.

12. Conformité RGPD

Les journaux techniques (serveurs, pare-feu, supervision) contiennent des données personnelles : identifiants, adresses IP, noms de postes rattachés à des personnes. Leur durée de conservation n’est pas définie et certains sont conservés depuis 2021.

Le registre des traitements tenu par la déléguée à la protection des données ne mentionne ni ces journaux, ni l’outil de ticketing, qui contient pourtant des données sur les salariés.

- Définir une durée de conservation pour chaque type de journal.
- Compléter le registre des traitements.

12. Usages de l’IA générative

Les entretiens révèlent un usage répandu d’assistants d’IA grand public par les salariés, y compris au sein du service informatique, pour rédiger des courriels, des procédures ou analyser des fichiers. Aucun outil n’est officiellement autorisé et aucune charte n’encadre ces usages.

Deux techniciens ont indiqué avoir collé des extraits de journaux techniques dans un assistant grand public pour diagnostiquer une panne. Ces extraits contenaient des identifiants et des adresses IP.

Depuis février 2025, le règlement européen sur l’IA impose aux entreprises qui utilisent ces outils de former leurs utilisateurs.

- Choisir et autoriser un outil professionnel.
- Rédiger une charte d’usage de l’IA.
- Former les équipes, en commençant par le service informatique.

13. Synthèse des constats

N°	Constat	Page	Risque
1	Douze comptes administrateurs sans double authentification	17	Critique
2	Sauvegardes non testées depuis neuf mois	22	Élevé
3	Trois serveurs hors support éditeur	9	Élevé
4	Alertes de supervision non relues le week-end	28	Élevé
5	Inventaire des postes incomplet	31	Modéré
—	Comptes VPN prestataires sans second facteur	13	Modéré
—	Comptes d’intérimaires restés actifs	16	Modéré
—	Mots de passe des comptes de service	19	Modéré
—	Absence de plan de reprise	23	Modéré
—	Partages SharePoint trop ouverts	25	Modéré
—	Fiche de changement sans volet supervision	32	Modéré
—	Usages non encadrés de l’IA	36	Modéré

13. Plan d’action recommandé

Horizon	Actions
0 – 3 mois	Second facteur sur tous les comptes à privilèges · alertes critiques envoyées à l’astreinte · partage du site de paie corrigé · migration de TRS-01 lancée
3 – 6 mois	Tests de restauration mensuels · isolement de la copie externe · rapprochement des inventaires · rubrique supervision dans la fiche de changement · charte IA
6 – 12 mois	Plan de reprise testé · renouvellement de PRT-01, FS-04 et SUP-01 · revue annuelle des habilitations · durées de conservation des journaux

Le cabinet recommande de présenter l’avancement de ce plan au comité de direction chaque trimestre.

Annexe A · Glossaire

Terme	Définition
Compte à privilèges	Compte disposant de droits d’administration
Second facteur	Preuve d’identité supplémentaire au mot de passe
Rançongiciel	Logiciel malveillant qui chiffre les données et exige une rançon
Support étendu	Période où l’éditeur ne fournit plus que des correctifs de sécurité
WMS	Logiciel de gestion d’entrepôt
Astreinte	Disponibilité d’un technicien en dehors des heures ouvrées
Plan de reprise	Procédure de redémarrage des services après un sinistre
Snapshot	Image instantanée d’un volume, utilisable pour un retour arrière

Annexe B · Entretiens et documents

Fonction rencontrée	Site
Directeur administratif et financier	Siège
Responsable informatique	Siège
Responsable d’exploitation	Siège
Administrateurs infrastructure (2)	Siège
Delivery manager	Siège
Techniciens support (4)	Siège, Lyon
Directeurs d’entrepôt (4)	Lyon, Rennes, Lille, Bordeaux
Chefs de quai (6)	Lyon, Rennes, Lille, Bordeaux
Déléguée à la protection des données	Siège

Documents consultés : schémas réseau, inventaires, procédures d’exploitation, fiches de changement 2025-2026, rapports de sauvegarde, contrats prestataires, registre des traitements.